

RansomShield — Aide-mémoire de soutenance

Discours complet — 8 min de présentation + 5 min de démo

Codjo Fréjus Loïc SANGRONIO — 11 juillet 2026

À lire au calme avant la soutenance ; en séance, s'en servir comme filet de sécurité, pas comme texte à réciter mot à mot. Le numéro « Diapo N » correspond exactement au numéro affiché dans le panneau de diapositives. Les **flèches vertes** sont des phrases à prononcer pour enchaîner vers la diapo suivante.

Diapo 1/22 — OUVERTURE

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Permettez-nous d'exprimer notre profonde reconnaissance pour votre présence. Ce jour est l'aboutissement de ces années de formation, un moment qui restera gravé dans notre parcours.

Le sujet de notre étude est intitulé : *Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé.*

C'est avec fierté et humilité que nous vous présentons RansomShield — un système conçu de bout en bout pour détecter et contrer les attaques ransomware, de manière contrôlée et traçable, avec une validation humaine à chaque étape décisive.

↪ **Voici comment s'articule cette présentation.**

Diapo 2/22 — SOMMAIRE

Notre présentation s'articule en cinq parties. Nous partirons du contexte et de la problématique, pour aller vers un état des lieux des solutions existantes, puis la conception et la réalisation. Nous conclurons par les perspectives et terminerons par une démonstration en conditions réelles.

↪ **Commençons par le contexte et la problématique.**

Diapo 4/22 — CONTEXTE

Aujourd'hui, les entreprises, les hôpitaux, les universités fonctionnent grâce à leurs données numériques. Le ransomware — un logiciel malveillant qui rend les données inaccessibles puis exige une rançon — exploite précisément cette dépendance. En 2023, ces attaques ont progressé de 73 % selon l'ENISA, avec un coût moyen de plus d'un million de dollars par incident. Ce qui est grave : sans outil adapté, une attaque passe en moyenne 21 jours sans être détectée.

↪ **Ce constat nous amène à la problématique centrale.**

Diapo 5/22 — PROBLÉMATIQUE

Les antivirus fonctionnent par reconnaissance d'empreintes : ils connaissent les menaces répertoriées. Mais face à une variante inédite, ils restent aveugles — et pendant ce temps, les données sont chiffrées, les sauvegardes effacées, les dommages deviennent irréversibles.

Il n'existe pas de solution libre et démontrable pour détecter ces attaques à partir de leurs comportements, avec un contrôle humain intégré à chaque étape.

Trois défis ont structuré ce travail : les variantes inconnues, la diversité des systèmes à surveiller, et le risque qu'une réponse automatique non validée cause elle-même des dommages.

→ Ces défis ont défini les six objectifs que voici.

Diapo 6/22 — OBJECTIFS

Six objectifs précis ont guidé ce travail : surveiller en temps réel les fichiers sur chaque terminal ; calculer un niveau de risque ; déclencher des alertes automatiquement. Le principe fondateur : chaque action passe par la décision d'un opérateur humain. L'accès est sécurisé par double authentification — mot de passe et code temporaire valide 30 secondes. Et pour valider l'ensemble, des scénarios d'attaque représentatifs ont été définis et exécutés.

→ Voyons maintenant les fondements théoriques de ce travail.

Diapo 8/22 — DÉFINITION & COMPORTEMENTS

Un ransomware agit toujours selon le même schéma : il renomme vos fichiers avec une extension inhabituelle pour les rendre illisibles, dépose une note de rançon, puis efface les sauvegardes pour rendre toute récupération impossible. Il utilise parfois des outils légitimes pour passer inaperçu.

Ce sont ces comportements observables — ces traces — qui forment la base de notre approche. Surveiller ces actions en temps réel permet de réagir avant que les dommages soient irréversibles.

→ Mais pourquoi les outils existants ne suffisent-ils pas ?

Diapo 9/22 — SOLUTIONS EXISTANTES

Des solutions existent — voyons pourquoi elles restent insuffisantes.

Les antivirus ne reconnaissent que les menaces déjà cataloguées dans leur base de données. Les SIEM — systèmes de centralisation des journaux d'activité — collectent des informations, mais sans chercher activement des comportements suspects. Les EDR — solutions de surveillance avancée des terminaux — sont très efficaces, mais leur coût les rend inaccessibles pour la grande majorité des organisations — PME, hôpitaux, administrations, associations — qui n'ont pas les budgets des grands groupes.

Notre solution occupe cet espace laissé vacant : libre, comportementale, déployable sur n'importe quelle infrastructure, avec un contrôle humain intégré à chaque étape — conçue pour les entreprises et organisations qui veulent se protéger sans dépendre de solutions propriétaires coûteuses.

→ Voyons maintenant comment ce système a été conçu.

Diapo 11/22 — ARCHITECTURE

Voici l'architecture générale — à lire de gauche à droite.

Un agent sur chaque terminal observe toute activité inhabituelle sur les fichiers. Ces observations sont transmises au serveur central, qui calcule un score de risque. Dès que ce score dépasse le seuil configuré, une alerte est générée et une action de protection est proposée à l'opérateur. C'est lui qui prend la décision finale. Le système n'agit jamais seul.

→ Voyons de plus près les quatre composants.

Diapo 12/22 — LES 4 COMPOSANTS

Notre système s'articule autour de quatre composants complémentaires.

L'agent : déployé sur chaque machine, il surveille les fichiers en temps réel et stocke tout localement — même hors réseau, rien ne se perd.

La console : le poste de commandement. L'analyste y voit tout et décide tout — alertes, incidents, file d'approbation, historique complet.

La découverte réseau : elle cartographie l'infrastructure automatiquement et propose les nouvelles machines. Aucune n'est intégrée sans validation explicite de l'administrateur.

Le simulateur : il reproduit les comportements réels des ransomwares dans un environnement isolé. C'est la même approche qu'un red team en SOC professionnel — tester sans risquer les données de production.

↪ **Qui sont les acteurs qui interagissent avec ce système ?**

Diapo 13/22 — DIAGRAMME USE CASE

Ce diagramme reflète la répartition exacte des droits codée dans le système.

L'administrateur contrôle tout : il gère l'infrastructure (réseaux, enrôlement des agents), configure les règles, lance les simulations et consulte le journal d'audit complet.

L'analyste SOC opère sur les événements : il supervise les agents en leur envoyant des commandes opérationnelles, traite les alertes et incidents, et approuve ou rejette chaque action de protection avant exécution.

La ligne de partage est nette : l'analyste ne peut ni modifier la configuration, ni consulter le journal d'audit global, ni lancer de simulation.

↪ **Passons maintenant à la réalisation concrète.**

Diapo 15/22 — CHOIX TECHNIQUES

Les choix techniques ont été guidés par trois critères : portabilité multi-OS, facilité de déploiement, et démontrable sans infrastructure coûteuse.

Le serveur et la console sont développés avec Laravel. L'agent de surveillance est en Python, portable sur Windows, Linux et macOS. Les tests ont été conduits sur trois machines virtuelles en réseau isolé. L'accès à la console est protégé par double authentification : mot de passe puis code temporaire valide 30 secondes.

↪ **Voyons concrètement comment l'agent et le moteur fonctionnent.**

Diapo 16/22 — AGENT & MOTEUR DE DÉTECTION

L'agent démarre, est reconnu par le serveur grâce à un jeton sécurisé, surveille les dossiers et envoie un signal de vie toutes les 30 secondes.

Pour le moteur de scoring : un fichier renommé `.locked` ajoute 80 points au score de risque. Une note de rançon dans le même dossier en ajoute 55. Le score atteint 135 — au-dessus du seuil critique de 80. En moins de cinq secondes, une alerte est générée et un incident est ouvert dans la console, en attente de la décision de l'opérateur.

↪ **Côté analyste, voici ce que la console SOC offre.**

Diapo 17/22 — CONSOLE SOC

Venons-en maintenant à la console SOC — l'interface que l'opérateur utilise au quotidien pour surveiller, réagir et rendre des comptes.

La console regroupe vingt-trois pages en quatre sections : supervision, infrastructure, détection et réponse, et configuration.

Ce qui est fondamental : chaque action proposée passe obligatoirement par la file d'approbation. L'analyste l'approuve ou la rejette explicitement. Aucune action ne s'exécute en silence.

Dès qu'une alerte est levée, l'opérateur est notifié par quatre canaux simultanément : interface web, e-mail, signal sonore et webhook.

↪ **Qu'est-ce que les tests ont donné ?**

Diapo 18/22 — TESTS & RÉSULTATS

Cinq scénarios d'attaque ont été définis, du chiffrement simple à la chaîne complète en 22 événements, exécutés sur trois machines virtuelles en réseau isolé — sans jamais déployer de malware réel. Pour chaque scénario, trois indicateurs ont été mesurés : délai de détection, intégrité des données, et complétude de la chaîne jusqu'à la décision de l'opérateur.

Les résultats sont constants : cinq scénarios exécutés, cinq détectés en moins de cinq secondes, zéro événement perdu.

↪ **Place maintenant à la démonstration live.**

Diapo 19/22 — DÉMONSTRATION LIVE — checklist 5 min, hors chrono

Suivre le guide de démonstration.

1. Console SOC ouverte : 3 agents en ligne
2. SSH sur `rs-client-1` : renommage `.locked` + note de rançon
3. Revenir sur la console : alerte critique apparue en moins de 5 secondes
4. **File d'approbation** : approuver l'action, montrer le rollback
5. **Timeline** : tout est horodaté
6. Simulation kill chain complète : 22 événements

↪ **Revenir à la présentation pour conclure.**

Diapo 21/22 — CONCLUSION & PERSPECTIVES

Notre solution couvre l'intégralité du cycle de traitement d'un incident : détection sur le terminal, analyse comportementale, alerte, décision de l'opérateur, archivage complet. Il est opérationnel, démontrable, construit sans malware réel.

Nous n'avons pas la prétention d'avoir épuisé le sujet : chaque remarque du jury est pour nous une opportunité de progresser et de mieux faire.

Les perspectives sont tracées : sécuriser les communications pour la production, affiner les rôles, et doter le moteur d'un apprentissage automatique pour reconnaître les anomalies avec plus de précision.

↔ **Nous restons à votre disposition pour vos questions.**

Diapo 22/22 — MERCI & QUESTIONS DU JURY — aide-mémoire

Dans un monde où les systèmes automatisent nos décisions, RansomShield rappelle une conviction simple : la machine peut détecter, mais c'est l'humain qui décide. Ce n'est pas une contrainte technique — c'est un choix éthique.

Merci pour votre aimable attention et pour le temps accordé à ce travail.

- **Python vs C/Go ?** → Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS
- **Fausses alertes ?** → Seuils configurables ; l'**opérateur humain** valide ou rejette avant toute action
- **Pourquoi pas HTTPS ?** → LAN contrôlé ; chiffrement TLS = 1^{re} perspective pour la production
- **Différence avec un antivirus ?** → L'antivirus reconnaît les empreintes ; RansomShield observe le comportement
- **Testé sur Windows ?** → Non, limite assumée ; Linux uniquement ; extension Windows = 1^{re} priorité d'évolution
- **Simulateur = test circulaire ?** → Le simulateur reproduit les **comportements fichiers** documentés (renommage, note de rançon, suppression sauvegardes) — pas la logique de détection. C'est l'approche standard du red team en SOC professionnel : tester sur des comportements réels sans déployer de malware en production. Fidèle aux cas documentés par l'ENISA.

*Reformuler la question avant de répondre. Garder les **captures d'écran** prêtes.*